

Lean Password Policy

Approving Authority	Risk and Compliance Committee
Approval Date	October 2024
Advisor Chair	Head of InfoSec
Next Scheduled Review	October 2025
Description	This Policy describes how employees and internal services should generate, store, and retrieve their passwords for cloud services they use on behalf of the company or personally.

Password Generation

Lean Technology employees must use complex passwords, where possible, for all of their accounts that have access to Lean Technology data:

- “Complex” passwords have at least one uppercase letter, one lowercase letter, one number, and one non- alphanumeric character, and are at least 8 characters long.
- All generated passwords for Lean Technology users and system accounts must be unique. Lean Technology employees may not reuse passwords that are or were used elsewhere, e.g. passwords used for personal accounts. A common way attackers obtain access to corporate resources is by using employees’ personal passwords that were obtained in breaches of other services.
- When creating end user passwords for the first time and/or during a password reset, the Security Team must also force the end user to change their password upon logging in for the first time.

The following password requirements applies to Lean developed Application Dashboard(DevPortal):

- Password complexity - passwords have at least one uppercase letter, one lowercase letter, one number, and one non- alphanumeric character, and are at least 8 characters long.
- Forced password expiration (180 days)
- Password History (checking previous 3 passwords)
- revoking the access after the three successive incorrect passwords
- Use of non-caching techniques

Lean Technology employees must always use two-factor authentication or Google Workspace login for all accounts that have access to Lean Technology data or mission critical infrastructure.

This includes:

Service	Authentication
1Password	2FA
AWS	2FA
Gsuite/Gmail	2FA
HubSpot	2FA
Slack	2FA
JumpCloud	2FA
Github	2FA
Nessus Tenable	2FA
hiBob	2FA
Notion	2FA

Teleport	2FA
Lean DevPortal	2FA

If you setup a password for any of the accounts listed above, then you need to setup two-factor authentication regardless of whether it supports Google Workspace login (e.g. JumpCloud, slack, Notion).

Password Requirements from Services

The services that Lean Technology uses to provide its offering also enforce password rules, which all users (including Lean Technology employees) must follow.

Managing and Storing Passwords

Lean Technology employees are required to use 1Password to manage their passwords and generate sufficiently complex passwords.

All Lean Technology system and user passwords must be encrypted when stored at rest within an application or database.

All Lean Technology system and user passwords must be encrypted during transmission.

Under no circumstances should Lean Technology employees share their account passwords with anyone, including other Lean Technology employees.

Disciplinary Action

Employees who violate this policy may face disciplinary consequences in proportion to their violation. Lean Technology management will determine how serious an employee's offense is and take the appropriate action:

- For minor violations, employees may only receive verbal reprimands.
- For more serious violations (e.g. a security incident or breach caused by reuse of personal passwords),

Employees may face severe disciplinary actions up to and including termination. Please refer to Disciplinary action Policy for further details.

Responsibility

The Risk and Compliance Committee and designated members are responsible for ensuring this policy is followed.